



University of Colombo, Sri Lanka

University of Colombo School of Computing

BACHELOR OF SCIENCE IN INFORMATION SYSTEMS

Second Year Examination - Semester I - UCSC AY22 [held in September/October 2025]

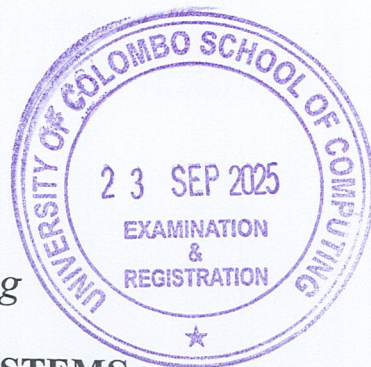
IS2204 - Information Systems Security

(Two (2) Hours)

Answer ALL questions

Number of Pages = 12

Number of Questions = 4



115

To be completed by the candidate

Index Number:

--	--	--	--	--	--	--	--

Important Instructions to candidates:

- I. Students should answer in the medium of English language only using the space provided in this question paper.
- II. Note that questions appear on both sides of the paper. If a page or a part of this question paper is not printed, please inform the supervisor immediately.
- III. Write your index number CLEARLY on each and every page of this Question paper.
- IV. This paper consists of 4 questions in 12 pages (including the Cover Page).
- V. Answer ALL questions.
- VI. Programmable Calculators and any electronic device capable of storing and retrieving text including electronic dictionaries, smart watches and mobile phones are not allowed.
- VII. Non-Programmable calculators are allowed
- VIII. Do not tear off any part of this answer book. Under no circumstances may this book, used or unused, be removed from the Examination Hall by a candidate.

To be completed by the examiners

1	
2	
3	
4	
Total	

Question 1

- (a) Triple-DES was created to extend the life of the DES algorithm. Explain how it provides backward compatibility with original DES.

(3 Marks)

Answer:

- (b)
(i) List **three (3)** options for combining **Encryption** and a **MAC** in a security protocol.

(3 Marks)

Answer:

- 1.
- 2.
- 3.

- (ii) For each option given for the question 1. (b).(i), identify which modern security protocol uses it.

(3 Marks)

Answer:

- 1.
- 2.
- 3.

(c)

(i) Explain the role of a Certificate Authority (CA) in the PKI hierarchy. What does your web browser trusting a CA means?

(5 Marks)

Answer:

(ii) Compare one major **advantage** and one major **disadvantage** of the **Web of Trust** model when compared to the **hierarchical** PKI model.

(5 Marks)

Answer:

(d) Explain the roles of **hashing** and **asymmetric** encryption in creating a digital signature that provides both integrity and non-repudiation.

(6 Marks)

Answer:

Question 2

- (a) You are tasked with designing secure solutions for three different scenarios. For each, recommend either **TLS**, **IPsec**, or **SSH** and justify your choice.

(6 Marks)

Answer:

	Scenarios	Protocol
(i)	Securing all communication between two corporate office networks over the public internet.	
(ii)	Providing a secure way for a system administrator to remotely log into a web server to check its logs.	
(iii)	Ensuring the confidentiality and integrity of data between a web browser and an e-commerce website.	

- (i) Compare and contrast IPsec **Transport Mode** and **Tunnel Mode**.

(2 Marks)

Answer:

- (ii) Draw a simple diagram showing the difference in how a TCP segment is encapsulated in **ESP Tunnel Mode** versus **ESP Transport Mode**.

(4 Marks)

Answer:

- (iii) Provide a specific real world use case best suited for **Transport Mode** and another best suited for **Tunnel Mode**.

(2 Marks)

Answer:

Transport Mode:

Tunnel Mode:

- (c) Define and differentiate between **identification**, **authentication**, and **authorization** with suitable examples.

(3 Marks)

Answer:

- (d) In **WebAuthn**, the Web server stores public keys instead of passwords.

- (i) Briefly Explain how WebAuth protocol works.

(5 Marks)

Answer:

- (ii) Explain how the WebAuth protocol reduces the risk of phishing attacks.

(3 Marks)

Answer:

Question 3

- (a) A network administrator wants to choose between a Host-based IDS (HIDS) and a Network-based IDS (NIDS).
(i) Compare **HIDS** and **NIDS** with examples.

(4 Marks)

Answer:

(ii) Which one would be more effective for detecting insider threats? Why?

(3 Marks)

Answer:

(iii) Which one would be better for detecting a DDoS attack? Why?

(3 Marks)

Answer:

(b) An **IDS** reports a high number of alerts, but after investigation, most turn out to be false alarms.

(i) Define **false positive** and **false negative** in IDS.

(4 Marks)

Answer:

False positive:

False negative:

- (ii) Briefly discuss the impact of too many false positives on a security team's efficiency.

(5 Marks)

Answer:

- (c) What are the roles of **Red**, **Blue**, and **Purple** Teams in cybersecurity operations? Give practical examples.

(6 Marks)

Answer:

Red Team:

Blue Team:

Purple Team:

Question 4

- (a) Differentiate between **threat**, **vulnerability**, and **risk** with a suitable example.

(6 Marks)

Answer:

- (b) Briefly discuss the **four (4) risk treatment strategies** with examples from a university environment.

(8 Marks)

Answer:

1.

2.

3.

4.

- (c) Provide an example for **administrative**, **physical**, and **technical controls**.

(3 Marks)

Answer:

Administrative Control:

Physical Control:

Technical Control:

- (d) A university Student Management System has the following data:

Asset Value = Rs. 500,000,

Exposure Factor = 50%,

Annualized Rate of Occurrence (ARO)= 0.5,

Mitigation cost = Rs. 30,000 per year

- (i) Calculate the Single Loss Expectancy (SLE)

(3 Marks)

Answer:

- (ii) Calculate the Annualized Loss Expectancy (ALE).

(2 Marks)

Answer:

(iii) Should the university spend on mitigation? Justify with cost–benefit analysis.

(3 Marks)

Answer:
